Maßnahmenplan

Betrieb: Muster Elektrotechnik e.U. Datum: 23. Oktober 2026

Erste Welle bis: 22. November 2026

16 Maßnahmen für Muster Elektrotechnik e.U., aus jeder Antwort, die „teilweise“ oder „noch nicht“ war. Drei Wellen: Was Fragebögen und Versicherer zuerst fragen, kommt zuerst. Eine Maßnahme ist erledigt, wenn ihr Nachweis im Nachweisordner liegt.

Welle 1 · bis 22. November 2026

Nr.	Maßnahme	Heute	Verantwortlich	Nachweis danach
1	Multi-Faktor-Authentifizierung für Fernzugriff (VPN, Remote Desktop), jedes Administratorkonto, die Cloud-Konsolen und das Online-Banking einschalten.	Teilweise: VPN ja, die Administrationskonsole der Cloud noch nicht	Inhaber oder Geschäftsführung mit Muster IT-Service GmbH	Bildschirmfotos oder Administratorbericht je System.
2	Tägliche automatische Sicherung aller Geschäftsdaten einrichten, mit einer Kopie außerhalb der Reichweite eines Angreifers: offline, auf einer gewechselten Platte oder in einer Cloud-Kopie, die sich vom Büro aus nicht löschen lässt.	Teilweise: täglich auf das NAS im Büro, keine Offline-Kopie	Inhaber oder Geschäftsführung mit Muster IT-Service GmbH	Sicherungseinstellungen und Zeitplan; wo die Kopie außer Reichweite liegt.
3	Einen Ordner aus der Sicherung zurückspielen, die Zeit stoppen, Datum, Dauer und Ergebnis notieren. Einmal im Jahr wiederholen.	Noch nicht	Inhaber oder Geschäftsführung mit Muster IT-Service GmbH	Protokoll des Wiederherstellungstests mit Datum und Dauer.
4	Die Notfallkarte dieses Toolkits drucken, aushängen, eine Kopie in die Lade der verantwortlichen Person und eine zur Vertretung nach Hause. Die Nummern vor dem Druck prüfen.	Noch nicht	Inhaber oder Geschäftsführung	Notfallkarte, ausgehängt und datiert.
5	Benennen, wer nach einem Vorfall prüft, ob personenbezogene Daten betroffen sind, und wer binnen 72 Stunden nach Kenntnis an die Datenschutzbehörde meldet. Beides auf die Notfallkarte.	Teilweise	Inhaber oder Geschäftsführung	Notfallkarte; die Namen in den Regeln.

Welle 2 · bis 21. Jänner 2027

Nr.	Maßnahme	Heute	Verantwortlich	Nachweis danach
6	Die Sicherheitsregeln für die Belegschaft auf ein bis zwei Seiten schreiben: Geräte, Passwörter, E-Mail, Zahlungen, was gemeldet wird und an wen. Die Leitung unterschreibt, jede Person bestätigt die Kenntnisnahme.	Teilweise	Inhaber oder Geschäftsführung	Unterschriebene Regeln mit Datum; Liste der Kenntnisnahmen.
7	Die Liste aller Konten je Person schreiben und eine Austrittscheckliste anlegen, die sie am Tag des Ausscheidens deaktiviert. Beim nächsten Austritt proben.	Teilweise	Inhaber oder Geschäftsführung	Kontenliste; Austrittscheckliste mit Daten.
8	Administratorrechte aus den täglichen Konten entfernen und getrennte Administratorkonten anlegen, die nur für die Administration benutzt werden.	Noch nicht	Inhaber oder Geschäftsführung mit Muster IT-Service GmbH	Kontenliste mit täglichen und Administratorkonten.
9	Einen Passwort-Manager für alle einführen und die Regel schreiben: ein langes Passwort je Konto, fünfzehn Zeichen oder mehr ohne zweiten Faktor, nur bei Verdacht geändert, gegen Leck-Listen geprüft.	Teilweise	Inhaber oder Geschäftsführung	Schriftliche Regel; Passwort-Manager eingeführt (Lizenz oder Bildschirmfoto).
10	Die Geräteliste schreiben: Gerät, Nutzer, System, unterstützt bis. Jedes Gerät ersetzen oder vom Netz nehmen, dessen System nicht mehr unterstützt wird.	Teilweise: keine schriftliche Liste; der Werkstattrechner läuft noch mit einem alten System	Inhaber oder Geschäftsführung mit Muster IT-Service GmbH	Geräteliste mit Daten.
11	Router oder Firewall aktualisieren, das Administratorpasswort ändern, die Fernadministration abschalten, das Gastnetz vom Betriebsnetz trennen.	Teilweise: Gastnetz ja, Firmware und Passwort unbekannt	Inhaber oder Geschäftsführung mit Muster IT-Service GmbH	Router-Einstellungen und das Datum der Prüfung.
12	Ein Vorfallsprotokoll anlegen: eine Seite je Vorfall mit dem, was passiert ist, auf welchem Weg, was gefehlt hat, was geändert wurde, wer es geprüft hat.	Noch nicht	Inhaber oder Geschäftsführung	Vorfallsprotokoll, auch wenn noch leer, mit Datum.
13	Eine halbstündige Einweisung zu Phishing, Passwörtern, Zahlungen und dem Meldeweg halten. Die Teilnehmerliste mit Datum und Inhalten aufbewahren. Einmal im Jahr und bei jedem Neueintritt wiederholen.	Noch nicht	Inhaber oder Geschäftsführung	Teilnehmerliste mit Datum und Inhalten.

Nr.	Maßnahme	Heute	Verantwortlich	Nachweis danach
14	Die Liste der Dienstleister schreiben, die Ihre Daten oder die Ihrer Kunden verarbeiten: Anbieter, Land, Zweck, Vertrag, Kontakt.	Teilweise	Inhaber oder Geschäftsführung	Dienstleisterliste mit Land und Zweck.
15	Von jedem Dienstleister, der personenbezogene Daten im Auftrag verarbeitet, den Auftragsverarbeitungsvertrag einholen, und in jeder Anbieterkonsole die Multi-Faktor-Authentifizierung einschalten und ein zweites Administratorkonto für eine zweite Person einrichten.	Teilweise	Inhaber oder Geschäftsführung mit Muster IT-Service GmbH	Verträge abgelegt; Konsoleneinstellungen.

Welle 3 · bis 21. April 2027

Nr.	Maßnahme	Heute	Verantwortlich	Nachweis danach
16	In die Regeln aufnehmen, dass der Kunde informiert wird, bevor ein Dienstleister gewechselt wird, der seine Daten verarbeitet; eine Vorlage für die E-Mail bereithalten.	Noch nicht	Inhaber oder Geschäftsführung	Regel; E-Mail-Vorlage.

Wiedervorlage

Fester Termin	23. Oktober 2027
Anlässe	Ein neuer Kundenfragebogen; ein Austritt oder der Wechsel einer Ansprechperson; ein neuer Dienstleister; eine Änderung der Sicherung; ein Vorfall

Erzeugt mit dem Sicherheitsnachweis-Toolkit von Scutoria aus den Antworten des Betriebs. Der Plan ist eine Zusage des Betriebs an sich selbst; die Termine sind seine eigenen. Passwortlänge von fünfzehn Zeichen (Maßnahme C6): NIST SP 800-63B-4, Juli 2025, Abschnitt 3.1.1.2, abgerufen am 19. Oktober 2026; siehe Handbuch, Frage C6. Quellenbasiert. Keine Rechtsberatung.